

Ethical hacking

Assessment: Analysis of Public Disclosure of a Banking Application Vulnerability

Introduction

Ethical hackers help organizations identify security weaknesses before cybercriminals can exploit them. However, discovering a vulnerability is one part of their responsibility. They must also disclose the vulnerability in a responsible and ethical manner.

In this scenario, a security researcher publicly tweets details of a vulnerability in a popular banking application within hours of discovering it without informing the bank first.

The researcher claims that "the public has a right to know". This action can be analyzed using standard vulnerability disclosure practices and ethical hacking.

Standard Disclosure practices

The most widely accepted method is Responsible disclosure also called coordinated vulnerability disclosure. In this process, the researcher privately reports the vulnerability to the affected organization and gives them enough time to fix the issue before making it public. This approach uses white allowing the company to release a security update.

Another method is Full disclosure where the vulnerability is made public immediately. Although this increases transparency and pressures organizations to act quickly, it also gives attackers information that can be used to exploit the vulnerability.

Responsible disclosure is considered the best practice because it balances public awareness with user safety.

Analysis of the scenario

In the given scenario the researcher did not follow responsible disclosure. Instead of informing the bank, the vulnerability was immediately shared on social media. This action exposed the banking application to cybercriminals before a security patch was available.

While the researcher believes that the public has the right to know, immediate disclosure can cause more harm than good.

Ethical hackers are expected to protect users and reduce risks, not increase them. Therefore the researcher's actions do not follow professional ethical standards.

Real world consequences

Publicly revealing the vulnerability without informing the bank can have serious consequences.

First attackers may quickly exploit the vulnerability and gain unauthorized access to customer accounts. This can result in financial losses and fraudulent transactions.

Second, sensitive customer information such as account details, passwords, and personal data may be stolen. This can lead to identity theft and misuse of customer information.

Third the bank's reputation may be damaged. Customers may lose trust in the bank's ability to protect their financial information and may stop using its services.

The bank must also spend significant time and money investigate the issue, developing a security patch, and responding to customer concerns.

In addition, if customers information is compromised the bank may face legal action, regulatory penalties, and compensation claims.

Ethical Evaluation

Ethical hacking is based on responsibility, reliability, integrity and minimizing harm. Although information the public is important, protecting users should always be the first priority.

Publishing technical details a fix is available increases the risk of cyberattacks and exposes innocent users to unnecessary danger.

Recommended Approach

The researchers should have followed responsible disclosure by privately reporting the vulnerability to the bank's security team immediately after discovering it.

The bank should have been given reasonable time to investigate after issue, develop a security patch, and deploy updates to users.

After the vulnerability had been fixed, the researcher could publicly disclose the findings and receive recognition for the discovery

This approach protects customers, promotes cooperation between researchers and organizations, and strengthens overall cyber security

Conclusion

The security researcher in this scenario failed to follow accepted vulnerability disclosure practices by publicly revealing details of a banking applications vulnerability without first notifying the bank

Although the intention may have been to inform the public, the action significantly increased the risk of cyberattacks by the following responsible disclosure practices. Security researchers contribute to a safer digital environment and help protect both organizations and the public from cyber threats.